



IAAG Transform

Project Assurance Plan: PA1266

Assurance started: 22-04-2026

Latest update: 24-Apr-26

IAAG Transform PA consultant: Mo Zaman



24/04/2026

Project Assurance Plan

Name of the Project Skyneychat

Key Project Contact Name	cesar.almendro@iaggbbs.com
PA Ref ID	PA1266
Operating Company	IAGT
Project Criticality	Medium
Date Project Engagement Closed	

CURRENT PHASE - PROJECT HEALTH ASSESSMENT

Project is on-track to meet / has met
all Assurance expectations

Project is on-track to meet / has met
all Assurance expectations

Project has met all assurance
expectations & legacy risks registered

Project may not meet all Assurance
expectations

Project has not met Assurance
expectations (risk acceptance req'd)

Project Description

Note: project description here has been taken directly from the front door self assessment from.

Rather than navigating static dashboard or writing complex queries, users can simply ask questions in natural language and receive immediate, structured answers, ranging from precise tables to dynamic visualizations and actionable insights. Powered by advanced natural language understanding, agent-based orchestration, and tightly integrated Power BI semantic models and knowledge documents, SkynetChat ensures that every response is grounded in trusted, governed enterprise data while remaining fully explainable.

SkynetChat introduces a new, intuitive way to consume data, shifting from passive reporting to interactive, on-demand intelligence.

The product is going to be used by IAG and IAG Transform.

High-Level Architecture

The SkynetChat system is built on a three-layer architecture designed to deliver scalable, intelligent, and reliable conversational analytics:

◆ User Interface Layer

Provides a seamless conversational experience where users can interact with enterprise data through natural language (text).

This layer dynamically renders responses as structured tables, visualizations, and insights, enabling intuitive and interactive data exploration.

◆ Agentic Orchestration Layer

Acts as the intelligence core of the system, coordinating the end-to-end reasoning process. A supervisory agent decomposes user queries and routes them to specialized AI agents (e.g., data querying, visualization generation, domain-specific analysis), ensuring accurate, explainable, and context-aware responses.

◆ Data and Knowledge Layer

Serves as the foundation of the platform, integrating both structured data (Power BI semantic models) and unstructured knowledge sources (Competitors financial reports). This layer ensures that all outputs are grounded in trusted, governed enterprise data.

AI Governance and Guardrails

To ensure reliability and trustworthiness, the AI system follows a set of governance rules that constrain how responses are generated. The system operates strictly within the boundaries of the defined data model.

Assurance Summary

The project description here is as conclusive as the information provided by the PM (project management) team during the AA (assurance analysis) meeting held on the 22.04.26. Note: If the scope changes or if there is any ambiguity in the summary here it remains the PM team's responsibility to highlight. If the project management team are seeking technical help with the solution, they are advised to reach out to SecurityArchitecture@iaggbbs.com, this team provides security, risk & architecture guidance around security controls to everyone incl. projects, and this option should be used for all your guidance needs from a security controls / solution viewpoint.

Cyber Project Assurance Analysis meeting held on the 22.04.26. Brief project summary and scope of work: IAG colleagues currently navigate multiple systems manually to gather operational information which can take a lot of time and manpower, this

initiative is outlined to deliver an AI-assisted chatbot 'Skynetchat' that will allow individuals to ask questions in natural language to retrieve the relevant data to support faster business response, and reduce the manual effort. Validation and accuracy will be UAT tested through use cases and human in the loop quality checks.

Tangible delivery:

-React and Vite used to build the frontend UI

-AWS 3009 account vended for backend API services, the Agentic Orchestration AI infrastructure to route request and response to and from the data source.

Notes:

-There might be external connection to the platform 'Skynetcaht' however, at this present moment this has been taken out of the delivery scope.

-Impact to sensitive data, not immediately as this might be a future endeavour however, PM have been advised that they take reasonable considerations early in the development phase to ensure security measures are robust to ensure design resilience. This has also been reflected in the evidence section below.

Project progress

Phase	Review Conducted and proposed next review date	Health assessment progress by phase	Control Deficiencies / Risks highlights to Risk Assessment
Assurance Analysis	25.03.26	Project is on-track to meet all Assurance expectations	No
Assurance Checkpoint	PM team to arrange	Project is on-track to meet all Assurance expectations	
Assurance Checkpoint		Choose an item.	
Assurance Pre-Go Live Sign off Checkpoint		Choose an item.	
Assurance Closure		Choose an item.	

Risks identified

This section documents all of the risks identified that the project may end up carrying into the production environment at the completion of the Project Assurance process. Risks potentially transitioning into the production environment should be raised and will be highlighted early to the IAG Transform risk management team; these risks may well end up being remediated during the project and will be closed where appropriate prior to 'go-live'.

If a risk is identified that cannot be remediated by the project team, IAG Transform risk management team needs to be engaged. Once it has been agreed that a risk needs to be registered, a [residual risk form](#) should be raised.

Ref No.	Risk Identified (Description)	NIST Control Ref	IAG Risk ID / OpCo Risk Reg ID	Impact to regulatory compliance?	Why control cannot be implemented	Has risk been remediated?	Requested to complete residual
---------	-------------------------------	------------------	--------------------------------	----------------------------------	-----------------------------------	---------------------------	--------------------------------

							risk form (Risk ID & Date)

Evidence Assessment Review

This section documents all of the relevant evidence and controls that should be implemented or provided (some may not be actioned yet), to ensure compliance. They will be reviewed, assessed and tracked during the course of the project to ensure they are fit for purpose. Any controls that cannot be met will be raised as risks and the project team will be asked to complete a residual risk form. **(This should not be considered as an exhaustive list, rather a list of key controls based on the items covered at assurance meetings).**

Ref No.	Evidence Item	NIST Control ref	Project phase	Required for Pre-go live signoff?	Date Agreed	Evidence Review Date	Evidence Rating	Comments
1	DPO Approval	Governance (ID.GV)		Y	22.04.26			Please provide evidence As this project will eventually impact sensitive data, it is important that your design engages early with the DPO team to ensure the correct guiderails are taken into consideration as its always difficult to bold on security measures/controls post implementation, please provide DPO approval evidence e.g. DPIA ID or DPO confirmation email.
2	Password settings, MFA, Federated Access, Role Based Access Control	Identity Management, Authentication and Access Control (PR.AC)		Y	22.04.26			Please provide evidence Please provide evidence of MFA enforcement, federated authentication model, and RBAC configuration as applicable (e.g. IdP screenshots, access policies, or design documentation). All authentications must have MFA enabled.
3	User Management	Identity Management, Authentication and Access Control (PR.AC)		Y	22.04.26			Please provide evidence Please provide evidence that IAGT IDAM is used for identity lifecycle management, with Agent access requests tracked via ServiceNow and solution identities managed through Corporate Directory or SailPoint as applicable.
4	Data in transit and data at rest are protected	Data Security (PR.DS)		Y	22.04.26			Please provide evidence Please provide evidence that data in transit and at rest is protected using industry standard encryption and secure protocols (e.g. TLS, AES).

							Also, provide evidence that data ingested into the IAG domain is security validated for any malicious activity If data encryption is not required please provide a business justification.
5	Security testing	Security Continuous Monitoring (DE.CM)		Y	22.04.26		Please provide evidence Note: All new and existing deployments/development that undergo modification or have configuration changes must transition through SecOps or equivalent teams to ensure adequate security testing takes place to mitigate risks. (This may include but is limited to: vulnerability scans / pen testing / segregation testing / SCA etc.)
6	Third Party Due Diligence	Supply Chain Risk Management (ID.SC)		Y	22.04.26		Please provide evidence All new and existing third parties doing something different or contractual changes must transition through our TPRM service – you can provide sign-off as evidence or TPRM ID.
7	RTO/RPO < 24 hours	Information Protection Processes and Procedures (PR.IP)		Y	22.04.26		Please provide evidence Note: If the solution should fall into SL1/2 category it remains the PM team's responsibility to ensure your 'Cyber Project Consultant' is made aware to ensure BCDR measures are taken into consideration appropriately to meet the SL levels.
8	Logging and Monitoring	Protective Technology (PR.PT)		Y	22.04.26		Please provide evidence Please provide evidence that logging and monitoring are enabled and that the solution is onboarded to the SOC for monitoring (e.g. SOC confirmation or logging architecture - as applicable)
9	Security Architecture Review			Y	22.04.26		Please provide evidence Please engage with SEC Arch team via SecurityArchitecture@iaggsbs.co m and provide their approval sign off Note: Subra has been engaged Note: Bedrock service as part of the ARB has been approved with the following foundational models only ; Anthropic, Amazon, Cohere & Mistral. If you project intends to use any other model(s) you must advise the Cyber Project Assurance consultants so appropriate steps can be taken to ensure the model has undergoes due diligence and has sign off before use.
10	UAT Approval	Risk Assessment (ID.RA)		Y	22.04.26		Please provide evidence UAT/Regression/Unit Testing as applicable
11	AI Risk Register	Risk Assessment (ID.RA)		Y	22.04.26		Please provide evidence Please engage with AI Risk Team via <u>AI Principles Risk Assessment (Page 1 of 19)</u>

Changes associated with this Project

This section will note any changes the Project will try to get through any CAB/Change Management process. While IAG Transform PA will not review the specific technical aspects of the change, they will review the concept of what the change is trying to achieve with the Project.

Change Number	Description	Implementation date	Comments
	PM team to provide all relevant change tickets including description		

Reviewer:

PA Consultant	Mohammed Zaman	22.04.26
PA Consultant	Mohammed Zaman	24.04.26
PA Consultant	Mohammed Zaman	
PA Consultant	Mohammed Zaman	



Appendices

Threat modelling using STRIDE

IAG Cybersecurity uses STRIDE as a model for identifying cybersecurity threats to help answer the question "what can go wrong in this system we're working on?" Each threat is a violation of a desirable property for a system:

Threat	Desired Property
Spoofing	Authenticity
Tampering	Integrity
Repudiation	Non-repudiability
Information Disclosure	Confidentiality
Denial of Service	Availability
Elevation of privileges	Authorisation

IAG Cybersecurity 15 Risk Categories.

IAG Cybersecurity in collaboration with OpCos across the Group has standardised on **15 Risk Categories**. When discussing risks, efforts should be made to have them correspond to one of these (ideally the most suitable).

Risk Category	Event	Cause
Insufficient asset management	There is a risk of IAG not being able to secure its entire IT estate / systems.	This is due to insufficient asset management (including asset discovery) capability maturity and coverage in IAG.
Non-compliance with required regulations	There is a risk of IAG being non-compliant with required information / Cyber security regulations.	This is due to insufficient maturity in information / cyber security controls in accordance with required security regulations and industry best practice.
Insufficient third party security assurance	There is a risk that a IAG being affected by a cyber security breach in its supply chain or partnerships.	This is due to insufficient third party security assurance capabilities at IAG.
Insufficient access management	There is a risk of cyber attackers successfully gaining un-authorised access to IAG systems and data.	This risk is due to insufficient users identity and access management controls for both ordinary and privileged roles.
Insufficient malware (ransomware) / cyber incidents protection & preparation	There is a risk of successful malware injection (e.g. ransomware) into IAG systems through social engineering attacks (e.g., phishing or spear-phishing) or other means and risk of delay in responding to the incident.	This is due to deficiencies in technical security control capabilities (e.g., antivirus, anti-malware, endpoint detection response etc), insufficient cyber security training and awareness for IAG colleagues, and insufficient maturity in incident response plans.
Outdated cyber security policies	There is a risk of weaknesses in IAG security posture.	This is due to outdated cyber security policies (not matching best practice) and inconsistent and insufficient IT security standards documentation.
Insufficient security on end of life / obsolete systems	There is a risk that IAG will be unable to secure some of its IT systems against modern Cyber threats and attacks.	This is due to incompatibility of security tooling with IAG's End Of Life / Obsolete systems (network, infrastructure, applications).
Insufficient attack surface management (internal & external)	There is a risk of successful cyber attack on IAG on-prem and Cloud estate.	This is due to insufficient Network (segmentation, DDoS protection, WAF) and other protect security controls to manage IAG's internal and external attack surface.
Insufficient data loss prevention	There is a risk of accidental and malicious data leakage in IAG.	This is due to insufficient Data Loss prevention controls on email (and other MS Office 365 applications), removable media, Cloud storage spaces, corporate devices and personal devices used for work as well as insufficient insider threat management programs.
Inadequate backups for disaster recovery	There is a risk that IAG may not be able to recover from a crisis cyber security event.	This is due to in-existent or insufficient understanding of dependencies between critical systems and their recovery orders. Also lack of understanding which critical systems have the right capability, Documentation, Testing & Reporting. This would lead to a prolonged recovery times.
Insufficient Assurance on Application Development	There is a risk that newly developed systems in IAG are vulnerable to cyber attacks.	This is due to insufficient secure development life cycle (SDLC) as well as insufficient configuration and system hardening controls capabilities in IAG software development environment.
Insufficient vulnerability management	There is a risk of successful cyber attack through vulnerability exploitation in IAG systems.	This is due to un-remediated vulnerabilities in IAG systems as well as insufficient patch management capabilities in IAG.
Insufficient security monitoring	There is a risk that IAG is unable to detect and monitor Cyber attacks.	This is due to insufficient maturity and coverage in security logging, monitoring and audit capabilities across IAG systems.
Insufficient business resiliency	There is a risk that IAG may not be able to continue the delivery of products or services at acceptable predefined levels following a disruptive incident.	This is due to the absence or inefficiency of Business Continuity management and implemented plans and procedures.
Customer identity security	There is risk of a successful cyber attack on IAG customer accounts.	This is due to insufficient passwords and identity management control for customer facing applications.

Published IAG Cybersecurity Policies and Standards

- [IAG Cybersecurity Policies and Standards on the IAG Groupwide Intranet](#)
- There may be local policies on OpCo Intranets to be aware of

NIST CSF (Cybersecurity Framework) 23 Key Security Control Categories

IAG Cybersecurity uses the internationally recognised NIST CSF to guide and measure security control effectiveness. When discussing controls, efforts should be made to have them correspond to one of these (ideally the most suitable).

Function	Category
IDENTIFY (ID)	Asset Management (ID.AM): The data, personnel, devices, systems, and facilities that enable the organization to achieve business purposes are identified and managed consistent with their relative importance to organizational objectives and the organization's risk strategy.
	Business Environment (ID.BE): The organization's mission, objectives, stakeholders, and activities are understood and prioritized; this information is used to inform cybersecurity roles, responsibilities, and risk management decisions.
	Governance (ID.GV): The policies, procedures, and processes to manage and monitor the organization's regulatory, legal, risk, environmental, and operational requirements are understood and inform the management of cybersecurity risk.
	Risk Assessment (ID.RA): The organization understands the cybersecurity risk to organizational operations (including mission, functions, image, or reputation), organizational assets, and individuals.
	Risk Management Strategy (ID.RM): The organization's priorities, constraints, risk tolerances, and assumptions are established and used to support operational risk decisions.
	Supply Chain Risk Management (ID.SC): The organization's priorities, constraints, risk tolerances, and assumptions are established and used to support risk decisions associated with managing supply chain risk. The organization has established and implemented the processes to identify, assess and manage supply chain risks.
PROTECT (PR)	Identity Management, Authentication and Access Control (PR.AC): Access to physical and logical assets and associated facilities is limited to authorized users, processes, and devices, and is managed consistent with the assessed risk of unauthorized access to authorized activities and transactions.
	Awareness and Training (PR.AT): The organization's personnel and partners are provided cybersecurity awareness education and are trained to perform their cybersecurity-related duties and responsibilities consistent with related policies, procedures, and agreements.
	Data Security (PR.DS): Information and records (data) are managed consistent with the organization's risk strategy to protect the confidentiality, integrity, and availability of information.
	Information Protection Processes and Procedures (PR.IP): Security policies (that address purpose, scope, roles, responsibilities, management commitment, and coordination among organizational entities), processes, and procedures are maintained and used to manage protection of information systems and assets.
	Maintenance (PR.MA): Maintenance and repairs of industrial control and information system components are performed consistent with policies and procedures.
	Protective Technology (PR.PT): Technical security solutions are managed to ensure the security and resilience of systems and assets, consistent with related policies, procedures, and agreements.
DETECT (DE)	Anomalies and Events (DE.AE): Anomalous activity is detected and the potential impact of events is understood.
	Security Continuous Monitoring (DE.CM): The information system and assets are monitored to identify cybersecurity events and verify the effectiveness of protective measures.
	Detection Processes (DE.DP): Detection processes and procedures are maintained and tested to ensure awareness of anomalous events.
RESPOND (RS)	Response Planning (RS.RP): Response processes and procedures are executed and maintained, to ensure response to detected cybersecurity incidents.
	Communications (RS.CO): Response activities are coordinated with internal and external stakeholders (e.g. external support from law enforcement agencies).
	Analysis (RS.AN): Analysis is conducted to ensure effective response and support recovery activities.
	Mitigation (RS.MI): Activities are performed to prevent expansion of an event, mitigate its effects, and resolve the incident.
	Improvements (RS.IM): Organizational response activities are improved by incorporating lessons learned from current and previous detection/response activities.
RECOVER (RC)	Recovery Planning (RC.RP): Recovery processes and procedures are executed and maintained to ensure restoration of systems or assets affected by cybersecurity incidents.
	Improvements (RC.IM): Recovery planning and processes are improved by incorporating lessons learned into future activities.
	Communications (RC.CO): Restoration activities are coordinated with internal and external parties (e.g. coordinating centers, Internet Service Providers, owners of attacking systems, victims, other CSIRTs, and vendors).

Security Testing with the Security Engineering Team

The way to access CyberOps Security Testing services is either by engaging with the team to carry out a scoping session via cyberops@iairgroup.com, or by raising a Penetration Testing – IAG Transform ticket in ServiceNow. The ticket should include the proposed scan type or testing approach, along with as much detail as possible to help accelerate delivery and testing.

Security testing activities include:

Security Test Type	Description	Timeline
OS and Network Devices Hardening Test	This is non-intrusive security review to validate the hardening of the OS/Network Devices. Usually requested for newly installed OS and network devices.	Response time: 2 Working days Resolution Time: 4 Weeks * *Availability of application team, code and pre-request for Pen testing
Ad-hoc Penetration Testing (Application, Web & Network)	This is in depth security testing to identify and exploit vulnerabilities in the application, network, mobile application etc. This is an intrusive testing and may disrupt the service. The security testing will be run only on non-production environments.	Response time: 2 Working days Resolution Time: 4 Weeks * *Availability of application team, code and pre-request for Pen testing
Vulnerability Scan (DAST - Dynamic Application Security Testing) On-demand vulnerability testing	This is a web application vulnerability scan to find any know or unknow web application related vulnerabilities by using automatic tool This scan is done to check for vulnerabilities on the application, network, server. Also, this scan can be used to verify for SSL/TLS version	Response time: 2 Working days Resolution Time: 4 Weeks * *Availability of application team, code and pre-request for Pen testing
Cloud Pentest	Cloud penetration testing is a vulnerability assessment and penetration test within a cloud network infrastructure such as: AWS, Microsoft Azure or Google cloud.	Response time: 2 Working days Resolution Time: 4 Weeks * *Availability of application team, code and pre-request for Pen testing
SAST Code review	Static application security testing (SAST), or static analysis, is a testing methodology that analyses source code to find security vulnerabilities that make your organization's applications susceptible to attack.	Response time: 2 Working days Resolution Time: 4 Weeks * *Availability of application team, Also dependent on code type
.COM release Vulnerability Scan	This is a web application vulnerability scan to find any know or unknow web application related vulnerabilities by using automatic tool This scan is done during the CAP release process before application goes live.	Response time 1 Working days Resolution Time: 1 Week * * Availability of release Environments
.COM release code review	Static application security testing (SAST), or static analysis, is a testing methodology that analyses source code to find security vulnerabilities that make your organization's applications susceptible to attack.	Response time 1 Working days Resolution Time: 1 Week * * Availability of release Environments